

Portfolio 7: Data in motion

Carl Rundkvist og Holger Pedersen

Choose a type of sensitive data e.g

- Student grades

Think about how that data is used (for example updating a student's details like a new address)

Student karakterer kan blive set, oprettet, ændret eller slettet. Det kan blive set af Student, Student+, Teacher. Det kan kun blive oprettet, ændret og slettet af Teacher, med godkendelse af service-admin.

Identify:

where data is encrypted

At rest. Encrypted i databasen hvor det opbevares.

In motion. Når en elev vil se sin karakter, så bliver karakteren decrypted på severen og derefter, encrypted af TLS når den sendes fra databasen til elevens browser.

where it is decrypted

In use. Decrypted i browseren når eleven læser det.

where it is processed

In use. I universitets platformens servers ram. Her udregnes gennemsnit og om den enkelte studerende er bestået.

where it is transmitted

In motion. Når det sendes over http ved brug af TLS, bliver det til https, til klientens browser.

Create a table to model exposure and risk

Stage	Data exposed	Who can access it	Risk
API response	Student's details	Logged-in user	Screen capture

Stage	Data exposed	Who can access it	Risk
Database	Student grades	(Read only: Student, Student+) Teacher, Service Admin	Information disclosure, screen capture. Tampering, forkert ændring af karakterer.
Browser	Student grades	Klient	Information disclosure, screen capture.

In motion	Student grades	Ondsindet aktør	Man-in-the-middle attack. Network-interseption Traffic-manipulation.

Identify controls to mitigate risks to data e.g.

TLS

token expiry

Applying principle of least privilege

Auditing and logging policy

Active Monitoring

Alle ovenstående tiltag bør tages i betragtning, eftersom at de alene ikke ville dække behovet for sikkerhed. Eksempelvis hvis man undlod TLS ville det skabe en svaghed og risiko for AitM attack (adversary-in-the-middle).

Stærk logging- og audit politikker gør det også muligt for incident response (active monitoring) at reaktivt følge spor ved en hændelse.

Least privilege princippet sørger for at roller for færrest muligt permissions, således at de ikke kan påvirke integritet på platformen.

Portoflio Part 2

Encryption-in-Use Research

Trusted Execution Environments

- Secure enclaves
- Homomorphic encryption

As part of your portfolio provide an explanation of these terms and how they are used to help protect data in use. Ask questions such as:

Secure enclaves.

How does the technique work?

Secure enclaves er et samlet navn for en præventiv teknologi imod insider threats. Det fungerer således at alt data in use kun bliver behandlet inde i CPU'ens memory. Alt applikationskode og data, er umuligt at tilgå, medmindre du kører inde i CPU'ens secure enclave. Det beskytter data og lagring lokalt og i cloud. Man kan køre applikationer i secure enclaven, og hvis de kører der, er applikationen også isoleret for selve operativsystemet.

What problem does it solve?

Det mitigerer insider threats som er et voksende problem, ved at gøre det muligt for brugeren at tilgå applikationer som kører inde i secure enclave.

Where is it used in practice?

Det bruges i organisationer med sensitive data/applikationer, som skal sikres imod insider angreb.

What are its limitations?

Det er svært at implementere applikationer fordi deres kode skal genskrives, så de kan køre inde i secure enclave.

Det kræver en specifik hardware fra CPU producenten. Det kan være dyrt hvis alle servere skal opgraderes til disse specifikke CPU'er. Hver producent bruger sin egen udviklingsmetode, så du kan ikke mixe og matche.

Homomorphic encryption

How does the technique work?

Dataen som er krypteret skal normalvis dekrypteres for at kunne bruges. Men med homomorphic encryption er det muligt at process data uden at det dekrypteres. Data forbliver altså i en krypteret tilstand, så det ikke kan læses af personen som arbejder med det.

What problem does it solve?

Homomorphic encryption mitigerer risikoen for at data bliver læst af uautoriserede brugere. En admin bør ikke nødvendigvis læse personfølsomme data for at kunne arbejde med dem. Derudover undgår man også at hvis nogen spoofer sig adgang til denne data, vil den forblive krypteret.

Where is it used in practice?

Et eksempel er allerede nævnt i den ovenstående besvarelse. Men homomorphic encryption er også oplagt til outsourced arbejde, hvor man ikke ønsker at dem som håndterer og arbejder med den følsomme data, skal kunne læse det.

What are its limitations?

Der opstår dog nogle vanskeligheder ved brug af homomorphic encryption, da det er en meget ressourcekrævende løsning som er direkte urealistisk for nogle programmer. Derudover er det kritisk at håndtere encryption keys korrekt. Da der ved sjusket håndtering opstår risiko for information disclosure.